Análise Estratégica de Riscos

Diagnóstico de Cibersegurança e Defesa Corporativa

24 de Outubro de 2023 | Diretoria de Defesa Cibernética

A Anatomia do Dano Corporativo

Danos Diretos

Afetam o núcleo do negócio imediatamente. Representam perdas tangíveis no exato momento da ocorrência do incidente.

Exemplos Clínicos:

Roubo de dados proprietários, prejuízos financeiros diretos ou paralisação de servidores locais.

Danos Indiretos

Impactam a operação de forma mediata ou secundária. Representam o efeito cascata e o prolongamento da interrupção operacional.

Exemplos Clínicos:

Incapacidade logística de cumprir contratos vigentes, multas regulatórias atrasadas e perda de reputação devido a falhas de infraestrutura.

Matriz de Análise de Riscos: Global Talent

Categoria	Risco	Probabilidade	Impacto	NÍVEL	Gravidade	Urgência	Tendência	Índice GUT	Prioridade
Interna	Vazamento de dados de usuários	2	5	10	5	5	4	100	Muito alta
Interna	Perda do banco de dados	1	5	5	5	4	4	80	Muito alta
Externa	Roubo do código fonte	3	5	15	5	4	3	60	Alta
Externa	Malware em computadores	2	2	4	4	3	3	36	Média
Externa	Queda de energia	5	4	20	3	3	2	18	Baixa

A Matemática do Perigo: Probabilidade × Impacto

Probabilidade × Impacto = Nível de Risco

- **Probabilidade**: Escala de 1 (Improvável) a 5 (Vai acontecer)
- **Impacto**: Escala de 1 (Criticidade Baixíssima) a 5 (Criticidade Gravíssima)

PROBABILIDADE		IMPACTO: INSIGNIFICANTE 1	MENOR 2	MODERADA 4	MAIOR 8	CATASTRÓFICA 16
RARO	1	1	2	4	8	16
IMPROVÁVEL	2	2	4	8	16	32
POSSÍVEL	3	3	6	12	24	48
PROVÁVEL	4	4	8	16	32	64
QUASE CERTO	5	5	10	20	40	80

Diagnóstico Prático: Por que a Queda de Energia (Global Talent) é Nível 20 (Vermelho)? Probabilidade Máxima (5) × Impacto Grave (4) = Nível 20.

Zonas de Decisão Corporativa

$R \leq 4$ Zona Tolerável	**Mandato:** Manter controles existentes.
$4 < R \leq 8$ Zona Significativa	**Mandato:** Avaliar a necessidade de novos controles.
$8 < R \leq 16$ Zona Séria	**Mandato:** Implementar novos controles imediatamente.
$R > 16$ Zona Intolerável	**Mandato:** Paralisar a atividade afetada imediatamente.

Síntese Estratégica:
O Paradoxo Risco vs. Prioridade

Risco Máximo, Prioridade Baixa

Queda de Energia

Nível de Risco	Índice GUT
20	18

Insight: Acontece com extrema frequência, elevando o Nível de Risco. Contudo, a tendência não piora e a urgência é facilmente administrável.
Prioridade final: Baixa.

Risco Mediano, Prioridade Crítica

Vazamento de Dados de Usuários

Nível de Risco	Índice GUT
10	100

Insight: Apesar de ocorrer com menor frequência, a gravidade é extrema, a tendência de colapso reputacional é imediata e a resposta exigida é "para ontem".
Prioridade final: Máxima.

Arquitetura de Contramedidas: O Funil de Defesa

1. Prevenção

O perímetro inicial. Torna a ocorrência da ameaça quase impossível. Ex: Antivirus, firewalls corporativos, políticas de senhas rigorosas e criptografia.

2. Detecção

A malha sensível. Monitoramento contínuo para acionar ações mitigadoras a tempo de impedir danos severos caso o perímetro primário seja violado.

3. Repressão

A resposta tática. Ações imediatas tomadas após a confirmação de um incidente. Ex: Acionamento automático de redundância de backups.

4. Correção

O protocolo de recuperação. Processo final para restaurar os ativos. A extensão do esforço corretivo depende do sucesso da camada de Repressão.

Estratégias Residuais de Retaguarda

Seguro (Transferência do Risco)

Método passivo acionado estritamente para aliviar perdas financeiras resultantes de incidentes catastróficos que não podem ser inteiramente prevenidos pelas camadas ativas.

Aceitação (Retenção do Risco)

Opção gerencial deliberada de assumir as consequências operacionais. Aplicada apenas quando as contramedidas ativas são financeiramente inviáveis em relação ao valor do ativo.

A Base de Evolução: Lições Aprendidas

Documentação compulsória de todos os controles, violações, falhas e acertos da operação. Esta é a inteligência basal que retroalimenta e fortalece o desenvolvimento futuro das mitigações.

NotebookLM

Diretrizes de Ação Imediata

⚠ Prioridade 1: Vazamento de dados de usuários (GUT 100) ⚠

- **Vetor Origem:** Ameaça Interna.
- **Contramedida Imediata Exigida:** Reforço absoluto nas camadas de Prevenção (Revisão estrita de Criptografia de banco de dados e Políticas de Acesso de usuários).

⚠ Prioridade 2: Perda do banco de dados (GUT 80) ⚠

- **Vetor Origem:** Ameaça Interna.
- **Contramedida Imediata Exigida:** Auditoria imediata nas camadas de Repressão e Correção (Validação urgente da redundância, isolamento físico e integridade dos backups operacionais).

SÍNTESE FINAL: A alocação orçamentária e de recursos da NotebookLM deve ser puramente ditada pelo Índice GUT, priorizando a blindagem contra ameaças de estabilidade interna sobre as flutuações externas crônicas.